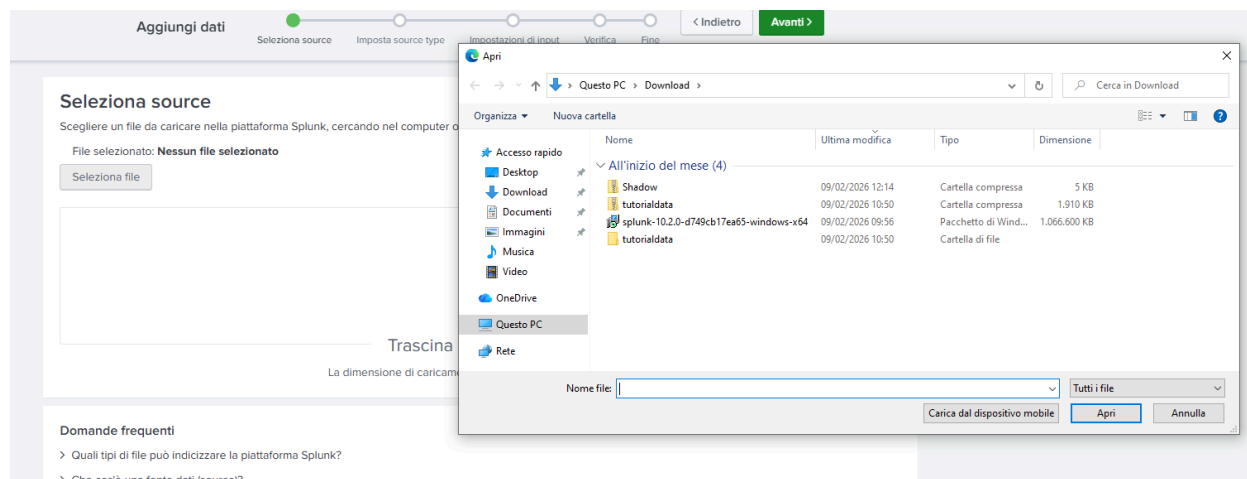


Report Analitico: Investigazione Forense su Log SSH tramite Splunk

1. Ingestione Dati e Configurazione dell'Ambiente

La fase iniziale richiede l'importazione del dataset compresso all'interno della piattaforma Splunk. Per garantire un'indicizzazione strutturata ed evitare la contaminazione dei sistemi, sono stati definiti i seguenti parametri architetturali:

- **Source Type:** Lasciato alla gestione della piattaforma, che assegna il tipo di formato ai dati in entrata, permettendone la formattazione intelligente e la successiva categorizzazione per le ricerche.
- **Host:** Modificato da "Valore costante" a "Segmento nel percorso" impostando il valore a 1. L'host rappresenta il nome della macchina di origine dell'evento. Questa configurazione istruisce Splunk a utilizzare il nome della prima cartella del percorso (es. `www1`, `www2`) invece del nome del file sorgente.
- **Indice:** I dati sono stati convogliati in un nuovo indice di "sandbox" denominato `tutorial12`. Questa separazione logica garantisce che i dati di produzione non vengano alterati o sporcati dai test di configurazione.



Source type

Il source type è uno dei campi di default che la piattaforma Splunk assegna a tutti i dati in entrata. Indica alla piattaforma Splunk il tipo di dati che si hanno, in modo che la piattaforma Splunk possa formattarli in modo intelligente durante l'indicizzazione. Rappresenta anche un modo per suddividere i dati in categorie in modo da semplificare le ricerche tra i dati.

Automatico Seleziona Nuovo

Host

Quando la piattaforma Splunk indicizza i dati, ciascun evento riceve un valore "host". Il valore host deve essere il nome della macchina da cui ha origine l'evento. Il tipo di input scelto determina le opzioni di configurazione disponibili. [Ulteriori informazioni](#)

☒ Valore costante
☐ Espressione regolare nel percorso
☐ Segmento nel percorso

Valore campo Host

Indice

La piattaforma Splunk archivia i dati in entrata come eventi nell'indice selezionato. Valutare l'uso di un indice "sandbox" come destinazione se si hanno problemi a determinare un source type per i propri dati. Un indice sandbox consente di risolvere i problemi a livello di configurazione senza conseguenze negative sugli indici di produzione. È sempre possibile modificare questa impostazione in un secondo momento. [Ulteriori informazioni](#)

Indice [Crea un nuovo indice](#)

Domande frequenti

> Come funzionano gli indici?

2. Smoke Test e Identificazione delle Anomalie

Completato il caricamento, è stata eseguita una prima ispezione (Smoke Test) per verificare la corretta ingestione dei file di log.

- L'esecuzione di una query SPL di base (`fail*` oppure `index=tutorial | stats count by sourcetype`) ha restituito un blocco di 33.253 eventi.

Nuova ricerca

✓ 33,253 eventi (prima di 26/02/26 17:59:48.000) Nessun campionamento degli eventi ▼

Eventi (33,253) Pattern Statistiche Visualizzazione

- L'ispezione visiva dei log ha evidenziato innumerevoli stringhe recanti la dicitura "Failed password", generate in rapida successione verso porte scansionate e provenienti dal medesimo IP target. * Il volume degli eventi (oltre 33.000) esclude in modo assoluto l'errore umano. Il pattern definisce un chiaro attacco automatizzato (tramite script o

botnet) volto a forzare l'autenticazione sul demone SSH tramite tecniche di brute-forcing/guessing delle credenziali.

i	Ora	Evento
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[5276]: Failed password for invalid user appserver from 194.8.74.23 port 3351 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[1039]: Failed password for root from 194.8.74.23 port 3768 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[5258]: Failed password for invalid user testuser from 194.8.74.23 port 3626 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[1165]: Failed password for apache from 194.8.74.23 port 4604 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[3760]: Failed password for invalid user mongodb from 194.8.74.23 port 2472 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure
>	07/02/26 21:58:11.000	Thu Feb 07 2026 21:58:11 mailsrv1 sshd[4998]: Failed password for mail from 194.8.74.23 port 1552 ssh2 host = DESKTOP-8CAJRTO source = tutorialdata.zip:\mailsv\secure.log sourcetype = www1/secure

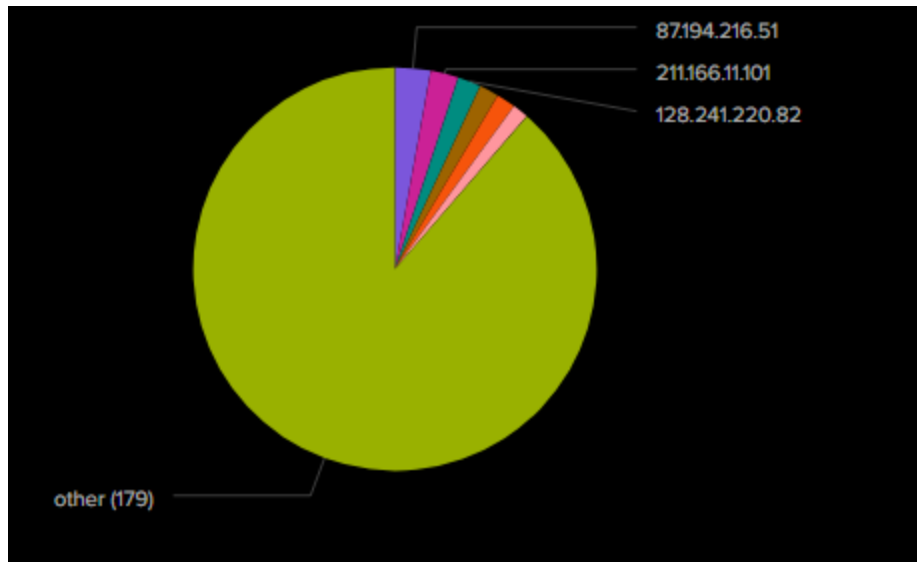
3. Estrazione e Isolamento della Minaccia

Per convertire l'intuizione in evidenza forense, è stato necessario quantificare e identificare gli aggressori. L'analisi è proseguita con l'estrazione degli indirizzi IP ostili tramite l'uso di espressioni regolari (regex): `index=tutorial "failed password" | rex field=_raw "from (?<attacker_ip>\d+\.\d+\.\d+\.\d+)" | stats count by attacker_ip | sort - count`

- La direttiva SPL è progettata per isolare l'IP sorgente di ogni tentativo fallito e aggregarne il conteggio decrescente.

attacker_ip	count
87.194.216.51	948
211.166.11.101	743
128.241.220.82	622
109.163.32.135	515
194.215.205.19	514
216.221.226.11	433
108.138.48.166	297
65.19.107.94	286
107.3.146.267	282

- La decodifica ha enucleato tre vettori d'attacco primari:
 - 87.194.216.51**: 948 tentativi.
 - 211.166.11.101**: 743 tentativi.
 - 128.241.220.82**: 622 tentativi.
- La ripartizione volumetrica è stata successivamente consolidata mediante una visualizzazione a torta per dimostrare l'impatto dei singoli nodi attaccanti.



4. Analisi del Target e Modus Operandi

L'indagine si è ristretta sul nodo principale (87.194.216.51) per profilare gli utenti bersaglio. È stata affinata la capacità di parsing dei log: `index=tutorial "failed password" "87.194.216.51" | rex field=_raw "for (invalid user )?(?<utente_bersaglio>\S+) from" | stats count by utente_bersaglio | sort - count`

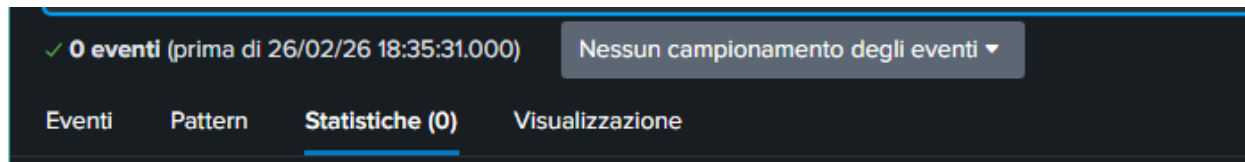
- L'espressione regolare avanzata intercetta dinamicamente il bersaglio scartando la variabile di sistema ("invalid user"), garantendo un'estrazione pulita degli username.
- I risultati delineano un'attività di enumerazione orizzontale (attacco a dizionario), mirata a colpire vasti insiemi di credenziali, con un'evidente polarizzazione (41 tentativi) volta all'ottenimento dell'utente privilegiato `root`.

utente_bersaglio		count
root		41
operator		38
admin		27
null		24
db		22
mailman		22
email		20
squid		20
irc		19
sys		19
system		19
administrator		18
jabber		18
daemon		17

5. Valutazione dell'Integrità Sistemica

La fase conclusiva dell'ispezione logica ha comportato la verifica di un'eventuale compromissione.

- La query finale mirata a identificare autenticazioni andate a buon fine ha restituito 0 eventi.
- Il parametro conferma formalmente che l'enumerazione orizzontale non ha innescato transizioni di stato. I perimetri di difesa e le policy di robustezza locali hanno assorbito l'onda d'urto del sistema automatizzato, validando l'integrità dell'ambiente rispetto al vettore in esame.



6. Raccomandazioni Architetture e Scenari di Resilienza

La registrazione di 948 tentativi non mitigati documenta una lacuna sistemica nelle dinamiche di reazione attiva dell'architettura di rete. Per incrementare la stabilità strutturale si delineano i seguenti interventi:

1. **Isolamento Dinamico del Nodo (Blackholing):** Imposizione di regole di blocco (dropping) al livello firewall host-based o di frontiera, al fine di invalidare in tempo reale il traffico della sorgente ostile e mitigare l'overhead del sistema di autenticazione.
2. **Mitigazione dell'Automazione (Rate Limiting):** Adozione di soluzioni di Intrusion Prevention System (IPS) preposte al pattern parsing dei log, atte ad applicare ban in modo automatico (temporaneo o permanente) in seguito a picchi anomali di fallimenti.
3. **Hardening del Livello Applicativo:** Ristrutturazione del file di configurazione del demone. Le metriche di sicurezza necessitano di:
 - Disabilitazione completa del login diretto in via privilegiata (es. `PermitRootLogin no`) per neutralizzare l'efficacia del bersaglio primario.
 - Transizione verso una postura Zero-Trust sulle credenziali alfanumeriche (es. `PasswordAuthentication no`), imponendo in modo assoluto l'autenticazione tramite crittografia asimmetrica a chiavi.